

IT AUDIT & OBSERVATION

TO: Chief Information Security Officer (CISO), PaySecure Solutions.

FROM: Shobana N, IT Auditor / GRC Analyst

DATE: September 2026

SUBJECT: Q3 2026 Production Database ITGC Access Control Audit

STANDARD: ISO 27001:2022 (Annex A.8.2, A.8.15) | ITGC Access Management

1. EXECUTIVE SUMMARY

During the Q3 2026 IT General Controls (ITGC) review, an audit of production database access logs was conducted for PaySecure Solutions. The objective of the audit was to evaluate user access controls, privilege management, and logging practices against ISO 27001:2022 standards.

The audit identified critical control breakdowns regarding Separations of Duties (SoD), excessive developer privileges, shared administrative account usage, and off-hours unauthorized access. Immediate remediation is required to mitigate risks of data loss and unauthorized system alterations.

2. AUDIT SCOPE & METHODOLOGY

- **Audit Scope:** Production Database Audit Logs (Log IDs 101–107).
- **Frameworks Evaluated:** ISO 27001:2022 Control A.8.2 (Privileged Access Rights), Control A.8.15 (Logging), and ITGC Access Control Policies.
- **Audit Procedure:** Custom SQL verification scripts were executed on production log data to detect privilege escalation, unauthorized DDL executions, and anomalous network connections.

3. DETAILED AUDIT FINDINGS (CCCR FRAMEWORK)

FINDING 1: Separations of Duties (SoD) Breakdown

- **Risk Level:** HIGH
- **Condition:** Log ID 103 indicates that developer account 'dev_john' successfully executed a Data Definition Language (DDL) command ('DROP TABLE payment_logs') directly in the production environment.
- **Criteria:** ISO 27001:2022 Control A.8.2 and ITGC SoD policy require strict separation between development roles and production environment write/drop permissions.

- **Cause:** Absence of Role-Based Access Control (RBAC) restrictions on developer database roles.
- **Impact:** Accidental or malicious deletion of production data, severe operational downtime, and non-compliance fine.
- **Recommendation:** Revoke direct DDL rights from developer accounts in production immediately. Implement Just-In-Time (JIT) administrative access requiring manager approval.

[EXHIBIT 1: SQL Audit Query Output - SoD Violation]

```
SELECT log_id, timestamp, db_user, user_role, client_ip, action_performed
FROM db_audit_logs
WHERE user_role = 'Developer'
AND (
    action_performed LIKE '%DROP%'
    OR action_performed LIKE '%ALTER%'
    OR action_performed LIKE '%GRANT%'
);
```

Audit Query Output confirming unauthorized DDL execution (Row 103) :

Query #1

Execution time: 0.31ms

log_id	timestamp	db_user	user_role	client_ip	action_performed
103	2026-08-01 11:00:00	dev_john	Developer	192.168.1.45	DROP TABLE payment_logs

FINDING 2: Unapproved Privilege Escalation

- **Risk Level: HIGH**
- **Condition:** Log ID 102 recorded DBA account 'admin_sarah' granting 'ALL PRIVILEGES' to 'dev_john' without a corresponding change request tickets or documented approval.
- **Criteria:** ITGC Access Control Policy requires the Principle of Least Privilege. Privileges must be granted based on business need and formally authorized.
- **Cause:** Lack of automated workflow integration between database access controls and ticketing systems (e.g., Jira/ServiceNow).
- **Effect / Impact:** Over-privileged accounts increasing the blast radius of potential insider threats or compromised developer credentials.
- **Recommendation:** Conduct a quarterly Access Request Recertification. Implement automated alerts whenever 'GRANT ALL PRIVILEGES' commands are executed.

[EXHIBIT 2: SQL Audit Query - Unapproved Privilege permissions]

```
SELECT log_id, timestamp, db_user, action_performed, client_ip
FROM db_audit_logs
WHERE action_performed LIKE '%GRANT%';
```

Audit Query Output confirming 'admin_sarah' granting ALL PRIVILEGES to 'dev_john'.

Query #2 **Execution time: 0.3ms**

log_id	timestamp	db_user	action_performed	client_ip
102	2026-08-01 10:30:00	admin_sarah	GRANT ALL PRIVILEGES TO dev_john	10.0.0.12

FINDING 3: Shared Administrative Accounts & Anomalous Off-Hours Access

- **Risk Level: HIGH**
- **Condition:** Log ID 104 recorded database access via a shared account ('shared_admin') accessing sensitive credit card tables at 02:15 AM from an untrusted public IP (185.220.101.5). Subsequent logs (105–107) recorded 3 consecutive failed login attempts.
- **Criteria:** ISO 27001:2022 Control A.8.15 and ITGC Access Policy mandate unique personal account attribution (non-repudiation) and restricted perimeter access via VPN/Bastion Hosts.
- **Cause:** Continued use of legacy generic administrative logins without IP whitelisting or MFA.
- **Effect / Impact:** Inability to establish accountability during incident response and high exposure to brute-force or credential-harvesting attacks.
- **Recommendation:** Deprecate generic shared accounts immediately. Enforce individual named DBA accounts, Multi-Factor Authentication (MFA), and Bastion Host IP restrictions.
-

[EXHIBIT 3: SQL Audit Query - Anomalous Access & Brute Force Pattern]

```
-- Query 3
SELECT log_id, timestamp, db_user, user_role, client_ip, action_performed
FROM db_audit_logs
WHERE (
    EXTRACT(HOUR FROM timestamp) NOT BETWEEN 8 AND 19
    OR (client_ip NOT LIKE '192.168.%' AND client_ip NOT LIKE '10.0.%')
);
```

```
-- Query 4
SELECT db_user, client_ip, COUNT(*) AS failed_login_count
FROM db_audit_logs
WHERE status = 'FAILURE'
GROUP BY db_user, client_ip
HAVING COUNT(*) >= 3;
```

Query execution evidence detecting unauthorized off-hours access and consecutive authentication failures via shared account 'shared_admin' :

Query #1 Execution time: 0.41ms

log_id	timestamp	db_user	user_role	client_ip	action_performed
104	2026-08-02 02:15:00	shared_admin	DBA	185.220.101.5	SELECT * FROM credit_cards
105	2026-08-02 02:16:00	shared_admin	DBA	185.220.101.5	FAILED LOGIN ATTEMPT
106	2026-08-02 02:16:05	shared_admin	DBA	185.220.101.5	FAILED LOGIN ATTEMPT
107	2026-08-02 02:16:10	shared_admin	DBA	185.220.101.5	FAILED LOGIN ATTEMPT

Query #2 Execution time: 0.26ms

db_user	client_ip	failed_login_count
shared_admin	185.220.101.5	3

4. MANAGEMENT REMEDIATION ACTION PLAN

Action Item	Owner	Priority	Target due date
Revoke Dev DDL Rights & Enforce RBAC	DBA Lead / SecOps	High	15 days
Deprecate Shared Accounts & Add MFA	IAM / SecOps Team	High	30 days
Configure SIEM Alerts for GRANTS	SOC Team	Medium	45 days
Establish Quarterly Access Review	IT Audit / GRC	Medium	Next audit cycle